NutriFitAI | Engineering Whitepaper

Technical System Behaviors & Architecture Specification

An exhaustive engineering analysis of recommendation lifecycles, dual-token authorization and session security, vector embeddings & semantic search, multi-LLM routing, and cryptographic audit chains.

Target Platform: Node.js / Express / MongoDB Atlas	**Client:** React Native (Expo) & Web	**Version:** 1.0 (Production)

---

1. Recommendation System & Refresh Mechanics

The NutriFitAI dashboard serves dynamically tailored recommendations across three domains: **food** (macronutrient and calorie-targeted meals), **workout** (multi-movement routines targeting untrained muscle groups), and **general** (biometric habit insights). Implemented in recommendationController.js and backed by MongoDB's recommendations collection.

Automated vs. Manual Refresh Triggers

Recommendations update through both background automated checks and rate-limited manual user requests:

- **Calendar Day Rollover:** Calculated on every request using today(timeZone) via the client X-Timezone header. At local midnight, old cards are retired and fresh cards generate on first dashboard visit.
- **Staleness Window (STALE_MS = 3 Hours):** If open cards are older than 3 hours, calling GET /api/recommendations automatically triggers background regeneration.
- **Data Mutation Invalidation (CHANGED_MIN_MS = 2 Minutes):** Logging, editing, or deleting meals (foodController.js:252) or updating goals/biometrics (profileController.js:258) calls invalidateRecommendations(userId), adding the user to an in-memory changed Set. On subsequent visits > 2 minutes later, recommendations regenerate to reflect newly logged calories and macros.
- **Manual User Trigger (POST /api/recommendations/refresh):** Allows user-initiated regeneration subject to strict cooldowns.

Cooldown Periods, Daily Limits & Deduplication

- **Manual Cooldown:** REFRESH_COOLDOWN_MS = 1 hour (60 minutes). Rapid refreshes reject with HTTP 429: *'These were just updated. Try again in a little while.'*
- **Daily Refresh Quota:** MAX_REFRESHES = 3 refreshes per day. A 4th attempt returns HTTP 429: *'You can refresh 3 times a day. Come back tomorrow.'*
- **Concurrency Deduplication:** An in-memory Map inflight coalesces concurrent requests per user so parallel taps attach to the same promise rather than spawning duplicate AI calls.
- **Dismissed Card Persistence:** replaceOpen deletes only cards with status: 'new'. Cards the user marked 'dismissed' or 'done' remain saved for that day and are added to a blacklist Set so they are never repeated.

Algorithmic Candidate Selection & Guardrails

- **Food Heuristics:** Evaluates nutrition_data.json against dietary restrictions using regexes (meat, dairy, gluten, pork). Requires remaining caloric headroom ≥ 150 kcal. Candidates scored by protein density: Score = (protein / kcal) * (0.8 + 0.4 * rand()).
- **Workout Heuristics:** Queries WorkoutSession.findRecent over past 14 days. Excludes completed exercises, groups 3–5 catalog movements, and prioritizes untrained muscle groups.
- **AI Selection & Fallback:** Passed to chatRec for strict JSON ranking. If AI times out or errors, immediately falls back to deterministic rule-based picks (source: 'rule').
- **Minor Protection:** Minors (< 18) and users with health notes receive a static nudge card (FOOD_NUDGE) directing them to conversational guidance without caloric targets.

---

2. Authorization Tokens & Session Security

NutriFitAI implements an enterprise dual-token authentication model combining short-lived stateless JWT access tokens with statefully tracked, rotated refresh tokens in browser-shielded cookies.

Attribute	Access Token	Refresh Token (nf_refresh)
Token Type	Stateless Bearer JWT	Stateful Session JWT
Secret & Alg	JWT_ACCESS_SECRET (HS256)	JWT_REFRESH_SECRET (HS256)
Lifespan	15 minutes (fixed)	1 day (standard) / 7 days (Remember Me)
Absolute Ceiling (sxp)	Bound to 15m lifespan	3 days (standard) / 30 days (Remember Me)
Claims	{ sub, email, role, type:'access', sid }	{ sub, type:'refresh', rmb, sxp, sid }
Storage Location	Memory & AsyncStorage	**httpOnly, Secure Cookie (path=/api/auth)**
Transmission	Authorization: Bearer header	Automated cookie transport

Refresh Token Rotation (RTR) & Absolute Session Ceilings

Calling POST /api/auth/refresh verifies the presented cookie, consumes it, and generates a brand-new rotated refresh token. To prevent indefinite session hijacking, an immutable session ceiling timestamp (sxp = loginTime + SESSION_MAX_MS) is embedded in the token. Once Date.now() ≥ sxp, refreshes are unconditionally rejected, destroying the cookie and forcing re-login.

Threat Mitigations & Attack Defenses

- **XSS Protection:** Refresh tokens reside in httpOnly cookies inaccessible to JavaScript. The access token has a narrow 15-minute exposure window.
- **CSRF Defense:** Cookie scoped strictly to path: '/api/auth'. Calling refresh returns the new access token in the JSON body, which cross-site origins cannot read due to CORS and Same-Origin Policy.
- **Immediate Role & Session Invalidation (requireFreshRole):** Bypasses token claims on admin/sensitive routes to query MongoDB live: verifies Session.isLive(sid) and checks account suspension (user.suspendedAt). Demoted or suspended users lose access instantly.
- **Brute Force Rate Limiting:** Tiered limiters throttle logins (10/10m per IP:email), refreshes (30/5m), and OTP verification (15/5m). Violations log automated audit alerts (auth.login.rate_limited).

- **Atomic One-Time OTPs:** Stored as SHA-256 hashes (never plaintext). Consumed atomically via findOneAndUpdate({ _id, consumedAt: null }), preventing race-condition replays. Resetting password revokes all active sessions across all devices.

---

3. Vector Embeddings & Semantic Search

NutriFitAI equips the AI coach (Nori) with semantic retrieval over food catalogs, workouts, and coaching guidance notes, implemented in embeddings.js and vectorIndex.js.

Layman's Terms vs. Technical Formulation

In Layman's Terms: Standard search matches exact letters. Searching for *'light dinner'* fails to find *'Sinigang na Bangus'* because the words don't match. Vector embeddings place concepts as coordinates on a high-dimensional digital map. Dishes that represent light, savory, high-protein evening meals sit in the same neighborhood. When you ask Nori a question, the system finds the closest items on the map in under 5 milliseconds.

In Technical Terms: Google Gemini (gemini-embedding-001) maps input strings into 768-dimensional dense vectors: e = f(text) ∈ R^768. All vectors are pre-normalized to unit Euclidean length: v_norm = v / ||v||_2. Because all vectors are unit-length, cosine similarity simplifies directly to the **Euclidean dot product**: Similarity(q, d) = q · d = ∑ (q_i * d_i). This eliminates expensive runtime square roots, enabling blisteringly fast linear scans over in-memory arrays.

Offline Pre-Computation & Runtime Query Pipeline

- **Offline Indexing (build-embeddings.js):** Foods, guidance notes, and exercise catalog items are extracted and hashed with SHA-1. Only changed or new records invoke Gemini API. Stored as Base64-encoded Float32Array buffers in coach_embeddings.json.
- **Memory Alignment:** At boot, vectorIndex.load() parses the index into an in-memory Map, copying buffer slices to guarantee 4-byte alignment required for SIMD vector instructions.
- **Topic Gating & LRU Caching:** Queries pass regex topic filters. A 200-item LRU cache returns recent queries in 0ms. On miss, Gemini Embeddings is queried with a strict 2.5-second timeout.
- **Circuit Breaker & Fallback:** On HTTP 429/5xx, quotaStore initiates cooldown (60s to 10m) and logs coach.embeddings.paused. Lookups gracefully degrade to deterministic regex/keyword matching (foodMatches).

---

4. Additional Core Technical Behaviors

Key architectural behaviors powering reliability, safety, and background processing across NutriFitAI:

Multi-LLM Dynamic Routing & Failover Chain (router.js)

Chat requests evaluate an ordered provider failover chain: **Groq (llama-3.3-70b)** → **Cerebras (llama3.1-70b)** → **Cloudflare Workers AI** → **Ollama (local)**. Recommendations run on an isolated chain (AI_REC_CHAIN) so background generation jobs never consume user conversational chat quotas. Circuit breakers enforce 20s burst cooldowns on 429s and 1-hour cooldowns on daily limit exhaustion.

AI Coach Safety Guardrails & Crisis Interception (safetyRules.js)

Pre-inference regex scanning checks active and prior 6 messages for self-harm, eating disorders, domestic abuse, and prompt injection (ignore previous instructions). Self-harm triggers immediate empathetic crisis protocols and emergency numbers (Philippine NCMH Crisis Hotline **1553** and **911**), overriding normal brevity rules. A deterministic static fallback reply guarantees an immediate crisis response if all external AI providers are offline.

Cryptographic Append-Only Audit Logging (AuditLog.js)

Mongoose pre-hooks block all update and delete queries on audit_logs. Every entry maintains an unbroken SHA-256 hash chain: hash_n = SHA256(chain + seq + hash_{n-1} + action + target + details). Daily background checks verify chain continuity; database tampering immediately triggers system.audit_chain.broken alerts. Sensitive PII (emails) are pseudonymized with HMAC-SHA256.

Automated Scheduled Background Maintenance (server.js)

Unref'd background timers execute recurring tasks: **Scan Image Purging (every 6h)** permanently deletes raw food photos older than 90 days from cloud storage while preserving nutritional metadata in MongoDB; **Account Deletion (every 6h)** purges accounts past their statutory grace period; **Daily Rollups (every 6h)** aggregates platform stats in Asia/Manila timezone; and **Reminders (every 15m)** dispatches notifications aligned with user daylight hours.

Client Network Resilience & Offline GET Caching (apiClient.js)

When an access token expires, the client pauses failed requests, coalesces concurrent calls into a single refreshPromise, calls /auth/refresh, and automatically replays requests with the new token. Idempotent GET endpoints leverage local caching (offlineCache.js), and network drops preserve user credentials without forcing a logout.